

COMPUTAÇÃO EM NUVEM I – AULA 6

Segurança e Boas Práticas na Nuvem

OBJETIVOS DE APRENDIZAGEM

Ao final desta aula, o aluno deverá ser capaz de:

- Entender os principais desafios de segurança em cloud computing
 - Compreender o modelo de responsabilidade compartilhada da AWS
 - Diferenciar autenticação e autorização
 - Entender o funcionamento básico do IAM
 - Compreender conceitos de usuário, grupo, política e permissões
 - Aplicar o princípio do menor privilégio
 - Reconhecer boas práticas básicas de segurança na nuvem
 - Entender riscos relacionados a credenciais e exposição pública
-

1. SEGURANÇA NA COMPUTAÇÃO EM NUVEM

Por que segurança é importante?

Na computação em nuvem:

- aplicações ficam acessíveis pela internet
- dados podem estar distribuídos globalmente
- múltiplos usuários acessam recursos compartilhados

Isso aumenta a importância de:

- controle de acesso
- proteção de dados
- gerenciamento de identidade
- monitoramento

Ideia central

Na nuvem:

Segurança não desaparece.
Ela muda de responsabilidade.

⚠ Principais riscos em cloud

◆ Credenciais vazadas

Exemplo:

- senha fraca
 - chave AWS exposta no GitHub
 - compartilhamento indevido
-

◆ Recursos públicos acidentalmente

Exemplo:

- bucket S3 público
 - banco de dados exposto
 - portas liberadas indevidamente
-

◆ Permissões excessivas

Usuários com acesso maior do que precisam.

◆ Má configuração

Grande parte dos incidentes em cloud ocorre por configuração incorreta.

2. MODELO DE RESPONSABILIDADE COMPARTILHADA

Conceito fundamental

Na AWS:

☞ segurança é compartilhada entre cliente e provedor.

◆ AWS é responsável pela segurança DA nuvem

Inclui:

- datacenters
 - hardware
 - rede física
 - energia
 - refrigeração
 - hypervisor
-

◆ Cliente é responsável pela segurança NA nuvem

Inclui:

- senhas
- usuários
- permissões
- aplicações
- dados
- configurações

- Security Groups
-

Frase-chave

A AWS protege a infraestrutura.
O cliente protege o que coloca nela.

Exemplos

Recurso	Responsável
Datacenter físico	AWS
Sistema operacional EC2	Cliente
Usuários IAM	Cliente
Hardware	AWS
Aplicação web	Cliente
Hypervisor	AWS

Exemplo importante

Se uma senha vazar:

🔑 a responsabilidade é do cliente.

3. IDENTIDADE E ACESSO

Problema

Como controlar:

- quem pode acessar
- o que pode acessar
- quais ações pode executar

Solução

IAM (Identity and Access Management)

4. O QUE É IAM?

Serviço da Amazon Web Services para gerenciamento de identidade e permissões.

Função principal

Controlar:

- autenticação
 - autorização
 - permissões
-

◆ Autenticação

Verificar quem o usuário é.

Exemplo:

- login
 - senha
 - MFA
-

◆ Autorização

Definir o que o usuário pode fazer.

Exemplo:

- criar EC2
- apagar S3

- visualizar RDS
-

Frase importante

Autenticação identifica.
Autorização permite.

5. COMPONENTES DO IAM

◆ Usuário IAM

Representa uma identidade individual.

Exemplo:

- desenvolvedor
 - administrador
 - aplicação
-

◆ Grupo IAM

Conjunto de usuários com permissões semelhantes.

Exemplo:

Grupo:

Desenvolvedores

Permissões aplicadas ao grupo.

◆ Política IAM

Documento que define permissões.

Estrutura lógica

Política responde:

- Qual ação?
- Em qual recurso?
- Permitido ou negado?

Exemplo conceitual

Usuário pode:

- iniciar EC2
- mas não apagar S3

Role IAM

Identidade temporária usada por serviços.

Exemplo:

EC2 acessando S3 sem senha fixa.

Conceito importante

Roles evitam armazenar credenciais diretamente na aplicação.

6. POLÍTICAS IAM

Definição técnica

Políticas são documentos JSON que definem permissões.

💡 Estrutura simplificada

```
{  
  "Effect": "Allow",  
  "Action": "s3:GetObject",  
  "Resource": "*"   
}
```

🔍 Significado

Campo	Função
Effect	Permitir ou negar
Action	Ação permitida
Resource	Recurso afetado

⚠️ IMPORTANTE

Políticas mal configuradas podem gerar:

- acesso indevido
 - vazamento de dados
 - exclusão acidental
-

🔒 7. PRINCÍPIO DO MENOR PRIVILÉGIO

📖 Conceito

Usuário deve possuir apenas as permissões necessárias.

✗ Exemplo ruim

Dar acesso total para todos.

✓ Exemplo correto

Desenvolvedor:

- pode iniciar EC2
 - não pode apagar banco de dados
-

🎯 Objetivo

Reduzir impacto de:

- erro humano
 - invasão
 - uso indevido
-

Frase importante

Quanto menos privilégios desnecessários, menor o risco.

🔑 8. MFA — AUTENTICAÇÃO MULTIFATOR

📖 O que é MFA?

Método que exige mais de uma forma de autenticação.

💡 Exemplos

- senha
 - aplicativo autenticador
 - token
-

🎯 Ideia

Mesmo que a senha vaze:

🔑 o invasor ainda precisa do segundo fator.

⚠️ IMPORTÂNCIA

MFA é uma das medidas mais recomendadas em cloud.

🌐 9. SECURITY GROUPS — REVISÃO DE SEGURANÇA

📖 Conceito

Firewall virtual da instância EC2.

Controla:

- portas abertas
 - origem da conexão
 - protocolos permitidos
-

💡 Exemplo perigoso

Liberar SSH para qualquer IP:

Porta Origem

22 0.0.0.0/0

⚠ Risco

Ataques automatizados na internet.

✓ Boa prática

Liberar acesso apenas para IPs necessários.

📁 10. SEGURANÇA EM STORAGE (S3)

⚠ Problema comum

Buckets públicos acidentalmente.

💡 Consequência

Arquivos sensíveis expostos.

🎯 Boa prática

- acesso privado por padrão
 - permissões explícitas
 - revisar políticas
-

11. CREDENCIAIS E CHAVES

Nunca:

- compartilhar senha
 - enviar chave por e-mail
 - subir credenciais no GitHub
-

Problema grave

Bots automatizados procuram chaves AWS expostas.

Consequência

- criação indevida de recursos
 - consumo financeiro
 - comprometimento da conta
-

12. BOAS PRÁTICAS GERAIS

Recomendações

- usar MFA
- aplicar menor privilégio
- revisar permissões regularmente
- evitar root account

- monitorar acessos
 - remover recursos não utilizados
 - evitar exposição pública desnecessária
-

13. ROOT ACCOUNT

O que é?

Conta principal da AWS.

Possui acesso total.

Risco

Se comprometida:

☞ toda a conta fica comprometida.

Boa prática

Usar root apenas para:

- configurações críticas
 - administração inicial
-

 **Uso diário deve ser feito com IAM Users.**

14. LAB (Sandbox) — EXPLORANDO IAM E SEGURANÇA

Parte 1 — Acessar IAM

No console AWS:

Pesquisar:

IAM

Parte 2 — Explorar seções

Verificar:

- Users
 - Groups
 - Policies
 - Roles
-

Parte 3 — Identificar permissões

Responder:

1. O que é um usuário IAM?
 2. Qual diferença entre usuário e role?
 3. Para que serve uma policy?
 4. Qual objetivo do grupo IAM?
-

Parte 4 — Security Groups

Abrir EC2.

Verificar:

- regras inbound
- portas abertas

- origem permitida
-

Parte 5 — Análise crítica

Perguntas:

1. Porta 22 aberta para qualquer IP é seguro?
 2. O que pode acontecer com permissões excessivas?
 3. Por que MFA é importante?
 4. Qual responsabilidade da AWS?
 5. Qual responsabilidade do cliente?
-

15. CENÁRIOS PRÁTICOS

Caso 1

Empresa dá acesso administrador para todos.

☞ risco elevado

Caso 2

Aplicação salva chave AWS diretamente no código.

☞ inseguro

Caso 3

Bucket S3 público por engano.

☞ vazamento de dados

Caso 4

Usuário com MFA habilitado.

🔒 maior segurança

QUESTÕES PARA PROVA

Conceituais

1. O que é IAM?
2. Diferencie autenticação e autorização.
3. O que é uma policy IAM?
4. O que é MFA?
5. Explique o princípio do menor privilégio.
6. O que é Security Group?
7. O que significa responsabilidade compartilhada?

Aplicadas

1. Uma empresa quer limitar permissões dos desenvolvedores. Qual princípio aplicar?
2. Qual recurso AWS controla identidade e acesso?
3. Qual risco existe ao expor chaves AWS?
4. Qual responsabilidade pertence à AWS?
5. Qual prática reduz impacto de vazamento de senha?

RESUMO PARA O ALUNO

Segurança em cloud depende de:

- controle de acesso
- permissões corretas
- proteção de credenciais
- configuração adequada

Na AWS:

- IAM controla usuários e permissões

- Security Groups controlam rede
- MFA aumenta segurança
- cliente e AWS compartilham responsabilidades

Boas práticas incluem:

- menor privilégio
- evitar acesso root
- revisar permissões
- proteger credenciais

PRÓXIMA AULA

APIs REST + Documentação

- conceito de API
- comunicação cliente-servidor
- REST
- JSON
- endpoints
- introdução ao Swagger/OpenAPI